



СОПЕВУ

**Отчет по экзамену курса
«Специалист центра мониторинга инцидентов ИБ»**

Оглавление

1. Теоретическая часть.	3
1.1. Вопрос 1.....	3
1.2. Вопрос 2.....	4
1.3. Вопрос 3.....	5
2. Практическая часть.	6
2.1. Задание 1.	6
2.2. Задание 2.	6
2.3. Задание 3.	7
2.4. Дополнительное задание.	7

1. Теоретическая часть.

1.1. Вопрос 1.

Вопрос: Какие типовые подразделения SOC вы знаете? Опишите их.

Ответ:

В рамках выполнения поставленных задач, в SOC организуются следующие типовые подразделения:

– **Отдел реагирования на компьютерные инциденты (Дежурная смена).**

Отдел реагирования на компьютерные инциденты. Специалисты дежурной смены (или первой линии) отвечают за своевременное обнаружение компьютерных инцидентов и первичное реагирование на них. Основными задачами является: фильтрация инцидентов ИБ (ложное срабатывание, срабатывание на легитимные действия, истинный инцидент); проведение мероприятий реагирования на истинные инциденты ИБ и закрытие их, если инцидент не требует проведения расследования. Дежурная смена может нести как круглосуточное, так и дневное (ночное) дежурство. Также возможно вынести обязанности дежурной смены на аутсорсинг. Специалисты отдела реагирования работают с системами мониторинга (IRP, SIEM), системами обнаружения вторжений (COB), системами предотвращения утечек (DLP), средствами защиты информации.

– **Отдел расследования компьютерных инцидентов (РКИ).**

Специалистов отдела расследования КИ иногда называют 2 линией SOC, но зачастую они являются отдельным подразделением. Их основной задачей является определение причины и ликвидация последствий КИ. Также на отдел РКИ в некоторых случаях может быть возложена задача Threat Intelligence (TI) и Threat Hunting (TH) (в части заведения в СЗИ новых правил для детектирования инцидентов)

– **Отдел администрирования средств защиты информации (СЗИ).**

Данное подразделение отвечает за развертывание, поддержание работоспособности средств ЗИ, совершенствование и масштабирование системы ЗИ. Администраторы средств ЗИ должны понимать принципы работы используемых ими средств, технологии на которых они построены. Обычно один-два специалиста отвечают за одну систему.

– **Отдел администрирования сетевой инфраструктуры.**

Специалисты данного отдела администрируют телекоммуникационное оборудование, контроллеры домена (если они есть), различные сервисы (серверы) мониторинга, организуют сетевую доступность как во внутренней сети, так и извне (VPN), осуществляют межсетевое экранирование. Администраторы сетевой инфраструктуры должны осуществлять мониторинг за состоянием сетевого оборудования, обеспечивать резервное копирование конфигурационных файлов критически важных сервисов (серверов), осуществлять мониторинг за каналом связи, предоставляемый провайдером.

– **Отдел оценки защищенности инфраструктуры.**

Данный отдел проводит мероприятия по выявлению угроз безопасности информации в организации (аудит информационной безопасности, тестирование на проникновение, имитация действий злоумышленников, редтиминг).

Также специалисты отдела оценки защищенности осуществляют моделирование угроз безопасности информации и выполняют мероприятия превентивного устранения уязвимостей – процесс моделирования угроз и процесс управления уязвимостями (Vulnerability Management) соответственно.

Вопрос 2.

Вопрос: Назовите задачи процесса ТН.

Ответ:

Threat hunting сокращенно ТН — это проактивный поиск угроз, которые не обнаружены стандартными средствами защиты информации.

Threat Hunting – это постоянный процесс. Он заключается в том, что аналитик, получив индикаторы компрометации в ходе процесса ТІ и зная, к какому этапу КА они относятся, предполагает, что система взломана и производит поиск признаков компрометации в тех местах, где они вероятнее всего могут появиться.

Этот процесс условно можно разделить на 2 части: поиск индикаторов компрометации и проверка гипотез о применимости техник злоумышленников в защищаемой инфраструктуре.

Цель ТН – это обнаружение следов присутствия злоумышленника, которые не обнаружили стандартные СЗИ.

Задача ТН – это проведение проактивного поиска угроз, заключающегося в поиске индикаторов компрометации в системе и оценке актуальности способов реализации техник злоумышленников для защищаемой инфраструктуры.

1.2. Вопрос 3.

Вопрос: Назовите задачи процесса VM

Ответ:

Управление уязвимостями (Vulnerability Management, VM) – непрерывный, циклический процесс выявления и устранения уязвимостей в инфраструктуре организации и состоит из следующих этапов :

- Инвентаризация активов.
- Выявление уязвимостей.
- Выработка рекомендаций.
- Устранение уязвимостей.
- Контроль устранения уязвимостей.

Цель процесса VM – повышение защищенности организации, путем закрытия актуальных уязвимостей.

Задачи процесса VM: – актуализация информации об устройствах в сети организации; – превентивное устранение уязвимостей; – накопление собственной базы знаний с уязвимостями и рекомендациями; – организация работы между отделами компании.

2. Практическая часть.

2.1. Задание 1.

Вопрос: Определить сценарий реагирования в соответствии с назначенным инцидентом в IRP и отработать по нему.

Ответ: В ходе анализа назначенного инцидента в IRP TheHive установлено, что инцидент соответствует сценарию реагирования №5 — обращение к ресурсам с подозрительной репутацией / скачивание подозрительных утилит.

Основанием является кейс “Download something suspicious from github”, связанный с хостом dns (192.168.230.128). В ходе расследования была выявлена подозрительная сетевая активность и последующая загрузка инструмента с GitHub.

Для отработки сценария были выполнены:

- анализ связанных кейсов;
- восстановление цепочки событий;
- анализ сетевой и endpoint активности;
- подготовка рекомендаций по блокировке активности.

2.2. Задание 2.

Вопрос: Выполнить задание, указанное в назначенном на Вас инциденте в IRP TheHive

Ответ:

В ходе выполнения задания в TheHive:

- проведен анализ связанных инцидентов;
- восстановлена цепочка событий;
- выполнен MITRE mapping;
- проанализированы нестандартные директории;
- подготовлены правила YARA, pfSense и COB;
- зафиксированы результаты расследования в task logs.

Yara правило:

```
rule Suspicious_Github_DirtyPipe
```

```
{
```

```
  meta:
```

```
    author = "Student_14"
```

```
  strings:
```

```
    $s1 = "dirtypipe"
```

```
$s2 = "github"  
$s3 = "CVE-2022-0847"
```

```
condition:  
  any of them  
}
```

Сканирование директорий:
/tmp
/home/Student_14/Downloads

Совпадений не обнаружено.

Suricata rule

```
alert tcp 192.168.230.128 any -> 140.82.121.3 443 (msg:"Suspicious Github  
tool download";sid:100001;rev:1;)
```

2.3. Задание 3.

Вопрос: Написать в отчет правило для межсетевого экрана (pfSense), заполнив следующие поля:

Action:
Interface:
Protocol:
Source:
Destination:

Ответ:

Action: Block
Interface: LAN
Protocol: TCP
Source: 192.168.230.128
Destination: 140.82.121.3
Description: Block suspicious Github download activity

2.4. Дополнительное задание.

Ответ:

1. Initial Access

Зафиксированы события sshd: authentication failed.

Предположительно выполнялся подбор учетных данных по SSH.

2. Suspicious Network Activity

На хосте dns (192.168.230.128) обнаружена подозрительная сетевая активность.

3. Tool Download / Delivery

Зафиксировано событие Download tools from Github.

Злоумышленник загрузил инструменты с внешнего ресурса.

4. Execution

На хосте выявлена suspicious endpoint activity.

Предположительно был выполнен запуск загруженных утилит.

5. Exploitation / Privilege Escalation

В TheHive обнаружено событие:

Dirty Pipe exploit activity detected (CVE-2022-0847).

Предположительно использовалась локальная уязвимость повышения привилегий.

6. Persistence / Artifact Placement

Обнаружены нестандартные временные директории:

- /tmp/cI
- /tmp/wSi
- /var/tmp/9y
- /var/tmp/vFe

Временные директории могли использоваться для хранения инструментов или сокрытия следов.

7. Continued Suspicious Activity

После эксплуатации продолжали фиксироваться suspicious endpoint activity и suspicious network activity.